

RISORSA 15 — Policy AI Interna (versione estesa)

Da “Intelligenza Artificiale in Pratica per chi lavora” — Aliosha Battaglini

Questa è la versione completa e approfondita della Policy AI Interna: un modello editabile, pensato per aziende dai 5 ai 50 dipendenti, che puoi adottare così com'è oppure personalizzare in profondità. Rispetto alla versione rapida, qui trovi sezioni aggiuntive su sicurezza tecnica, monitoraggio, formazione strutturata, sanzioni e conformità normativa. È il documento giusto se vuoi una policy solida da mostrare a clienti, revisori o consulenti, senza dover partire da zero.

Come usare questa policy

1. **Compila i placeholder.** In tutto il documento trovi tre campi tra parentesi quadre: **[AZIENDA]** (il nome della tua azienda), **[RESPONSABILE AI]** (la persona che coordina l'uso dell'AI) e **[DATA]** (la data di entrata in vigore). Sostituiscili ovunque compaiano usando la funzione “trova e sostituisci” del tuo editor di testo. Troverai anche alcuni campi opzionali tra parentesi quadre (ad esempio gli scopi d'uso o lo strumento di password manager): compilali o eliminali se non pertinenti.
2. **Adatta i contenuti alla tua realtà.** Modifica gli strumenti adottati, gli scopi d'uso e gli esempi di dati in base a come lavori davvero. Una policy generica non serve a nessuno: la sua forza sta nei dettagli concreti della tua azienda.
3. **Nomina subito un [RESPONSABILE AI].** Non serve un esperto di tecnologia: basta una persona di fiducia che faccia da punto di riferimento per dubbi, autorizzazioni e segnalazioni. È la figura attorno a cui ruota tutta la policy.
4. **Fai firmare la policy.** Distribuisci il documento a tutti i dipendenti e collaboratori e raccogli il modulo di accettazione firmato che trovi in fondo. La firma trasforma un documento in un impegno.
5. **Rivedi ogni 6 mesi.** Gli strumenti AI cambiano in fretta e le normative evolvono: fissa in calendario una revisione semestrale a partire da **[DATA]**.

Suggerimento: parti da poche regole applicate davvero, non da molte regole ignorate. Meglio una policy breve e rispettata che un regolamento perfetto che nessuno legge.

Intestazione della policy

Policy AI Interna di **[AZIENDA]**

Versione 1.0 — entrata in vigore: **[DATA]** — Responsabile dell'attuazione: **[RESPONSABILE AI]**

Documento approvato dal legale rappresentante di **[AZIENDA]**.

1. Scopo e ambito di applicazione

La presente Policy regola l'uso degli strumenti di intelligenza artificiale generativa (di seguito “AI”) all'interno di **[AZIENDA]**. Si applica a tutti i dipendenti, collaboratori e consulenti esterni che utilizzano strumenti AI per attività riconducibili a **[AZIENDA]**, indipendentemente dalla forma contrattuale del rapporto.

L'AI viene introdotta in azienda per supportare e amplificare il lavoro delle persone, non per sostituirle. La responsabilità di ogni contenuto, decisione e azione resta sempre umana. Gli strumenti AI sono un supporto: non sono autori autonomi e non sollevano nessuno dalla responsabilità del proprio lavoro.

2. Strumenti AI ufficialmente adottati

[AZIENDA] ha adottato i seguenti strumenti AI per uso lavorativo. L'uso di altri strumenti AI per scopi aziendali deve essere preventivamente autorizzato dal **[RESPONSABILE AI]**.

- *ChatGPT Team / Plus* — per [SCOPO, es. redazione bozze, ricerca, analisi testi, supporto operativo]
- *Claude Pro / Team* — per [SCOPO, es. scrittura raffinata, analisi documenti lunghi, ragionamento complesso]
- *NotebookLM* — per [SCOPO, es. interrogare documenti aziendali interni e fare ricerca]
- *Microsoft Copilot 365* — per [SCOPO, es. supporto in Word, Excel, Outlook]
- *[Eventuali altri strumenti specifici della tua azienda]*

Privilegia sempre i piani aziendali (Team / Enterprise / Business): offrono garanzie migliori sulla riservatezza dei dati e, in genere, non utilizzano i tuoi contenuti per addestrare i modelli.

3. Classificazione dei dati

Per capire al volo cosa puoi inserire in uno strumento AI, classifica ogni informazione in uno di questi tre livelli. Nel dubbio, sali sempre di livello: è meglio trattare un dato come più sensibile di quanto sia, che il contrario.

Livello	Esempi	Regola d'uso AI
Pubblico	Brochure, sito web, comunicati stampa, listini già pubblicati, contenuti social ufficiali	Utilizzabile liberamente, anche su strumenti gratuiti
Interno	Procedure, bozze, presentazioni interne, dati aggregati senza nomi, verbali di riunione	Solo su strumenti aziendali approvati; evita dettagli identificativi
Riservato	Dati personali, contratti, credenziali, dati sanitari, segreti industriali, dati finanziari	Vietato l'inserimento; in caso di reale necessità chiedi al [RESPONSABILE AI] e usa solo account aziendali con contratto sul trattamento dati

4. Dati che NON vanno mai inseriti negli strumenti AI

I seguenti dati non vanno mai inseriti in chat AI pubbliche, gratuite o di terze parti non autorizzate. Possono essere usati esclusivamente sui piani aziendali approvati (Team / Enterprise con contratto di trattamento dati conforme al GDPR) e solo quando strettamente necessario per il compito.

- Dati personali identificativi di clienti, fornitori, dipendenti (nomi, email, telefoni, indirizzi, codici fiscali)
- Listini prezzi confidenziali e condizioni commerciali specifiche
- Contratti firmati e accordi di riservatezza (NDA)
- Categorie particolari di dati personali (art. 9 GDPR): dati sanitari, biometrici, religiosi, opinioni politiche e simili
- Password, credenziali, chiavi API e altri segreti tecnici
- Segreti industriali, formule, processi protetti, brevetti in fase di registrazione

- Dati finanziari sensibili (saldi bancari, IBAN, dati di pagamento)

Quando un dato sensibile non è davvero indispensabile per il compito, anonimizzalo o pseudonimizzalo prima di inserirlo. Spesso all'AI basta la struttura del problema, non i nomi reali.

5. Attivazione di nuovi abbonamenti AI

Solo il **[RESPONSABILE AI]** (con il supporto del referente tecnico, dove presente) può attivare nuovi abbonamenti AI a nome di **[AZIENDA]**. È vietato l'uso di account personali per scopi aziendali, anche solo in via temporanea.

Il motivo è concreto: gli account personali e gratuiti non offrono le protezioni dati previste dai piani aziendali e i loro contenuti possono essere utilizzati per l'addestramento dei modelli. Un dato aziendale inserito in un account personale è, di fatto, un dato fuori controllo.

6. Rilettura e approvazione dei contenuti

Tutti i contenuti generati con AI che vengono inviati esternamente (clienti, fornitori, partner, autorità) o pubblicati pubblicamente devono essere riletti e approvati da una persona qualificata prima dell'invio o della pubblicazione.

La responsabilità del contenuto rimane sempre umana. Gli errori nei contenuti generati con AI sono imputabili alla persona che li ha approvati e inviati, non allo strumento.

Per i contenuti puramente interni (note, riassunti, bozze di lavoro che non escono dall'azienda) è ammesso un livello di controllo più leggero. Resta comunque la responsabilità individuale sulla correttezza delle informazioni che si usano per prendere decisioni.

7. Gestione degli errori AI (allucinazioni)

L'AI può generare informazioni errate o inventate, le cosiddette *allucinazioni*, in particolare su numeri, citazioni, fonti, riferimenti normativi e dati specifici. Per questo:

- Tutti i numeri, i dati statistici, le citazioni e i riferimenti normativi prodotti dall'AI vanno verificati con fonti indipendenti prima di essere usati esternamente.
- In caso di errore rilevato in un contenuto già utilizzato all'esterno, notificare immediatamente il **[RESPONSABILE AI]**.
- Documentare il caso (cosa è successo, chi era coinvolto, quando, con quali conseguenze).
- Adottare misure correttive (rettifica al destinatario, comunicazione al cliente, ecc.).
- Aggiornare le procedure interne se l'errore è ricorrente o potenzialmente grave.

8. Trasparenza verso clienti, fornitori e autorità

L'uso dell'AI a supporto dell'attività di **[AZIENDA]** è dichiarato nell'informativa privacy aziendale ([LINK O RIFERIMENTO]). Per i contenuti in cui la trasparenza è particolarmente rilevante (testimonianze, recensioni, voci attribuite a persone reali, contenuti che imitano persone esistenti) va sempre dichiarato esplicitamente l'uso dell'AI.

9. Ruoli e responsabilità

Ruolo	Responsabilità principali
Legale rappresentante / Amministratore	Approva gli acquisti AI, valida la policy, interviene nei casi di violazione grave
[RESPONSABILE AI]	Definisce gli strumenti, gestisce accessi e abbonamenti, fa audit, risponde ai dubbi, aggiorna la policy ogni 6 mesi
Referenti per area	Applicano l'AI nei loro processi, mantengono prompt e configurazioni, formano i colleghi del proprio team
Dipendenti e collaboratori	Usano solo strumenti approvati, rileggono i contenuti, rispettano i livelli di sensibilità, segnalano gli errori, completano la formazione

10. Sicurezza tecnica

Tutti gli account AI aziendali devono rispettare i seguenti requisiti minimi:

- Autenticazione a due fattori (MFA) attiva e obbligatoria
- Accesso individuale: nessun account condiviso tra colleghi
- Single Sign-On (SSO) integrato con i sistemi aziendali, quando possibile
- Password gestite tramite password manager aziendale ([STRUMENTO]), mai condivise via mail o chat
- Disattivazione immediata dell'account quando una persona lascia l'azienda

11. Formazione e onboarding

- Ogni dipendente o collaboratore che riceve accesso a uno strumento AI aziendale completa, prima dell'uso, un breve modulo formativo (durata indicativa: 2-4 ore) che copre i principi base dell'AI, la pratica sui prompt, le regole di sicurezza e la simulazione di casi pratici.
- Ogni nuovo arrivato riceve questa policy durante l'onboarding e la firma prima di usare gli strumenti AI.
- Il **[RESPONSABILE AI]** organizza almeno una sessione di aggiornamento all'anno su strumenti approvati, rischi e buone pratiche.
- Le novità rilevanti (nuovi strumenti, nuove regole) vengono comunicate tempestivamente a tutto il personale.

12. Monitoraggio e audit

Il **[RESPONSABILE AI]** effettua almeno con cadenza trimestrale:

- Verifica degli account attivi e dei costi
- Verifica degli accessi (chi entra e chi non dovrebbe più entrare)
- Controlli a campione (spot check) sui contenuti generati con AI
- Aggiornamento della policy quando cambiano le normative o gli strumenti adottati

I controlli sul lavoro delle persone vanno svolti nel rispetto dello Statuto dei Lavoratori (legge 300/1970): il monitoraggio riguarda gli account e i processi, non la sorveglianza individuale.

13. Sanzioni in caso di violazione

La violazione delle regole della presente Policy può comportare azioni disciplinari secondo quanto previsto dal CCNL applicato e dal Codice Disciplinare aziendale, fino al licenziamento per giusta causa nei casi più gravi (ad esempio l'inserimento intenzionale di dati riservati in account pubblici con conseguente danno per l'azienda). L'obiettivo non è punire, ma proteggere le persone, i clienti e l'azienda.

14. Revisione periodica e conformità

Questa policy viene rivista almeno ogni 6 mesi a partire da **[DATA]**, e comunque ogni volta che cambiano in modo rilevante gli strumenti adottati o il quadro normativo. I riferimenti normativi principali sono:

- Regolamento UE 2016/679 (GDPR)
- Regolamento UE 2024/1689 (AI Act)
- Legge italiana 132/2025 in materia di intelligenza artificiale
- Statuto dei Lavoratori (legge 300/1970), per gli aspetti relativi al monitoraggio dei dipendenti

15. La regola d'oro

Nel dubbio, non inserire il dato e chiedi al [RESPONSABILE AI]. Una domanda in più costa pochi minuti; un dato riservato finito nel posto sbagliato può costare molto di più.

Modulo di accettazione della policy

Da compilare e firmare da parte di ogni dipendente e collaboratore prima di usare gli strumenti AI.

Il sottoscritto / la sottoscritta _____ dichiara di aver letto e compreso la Policy AI Interna di **[AZIENDA]** versione 1.0, in vigore dal **[DATA]**, e si impegna a rispettarla pienamente.

Data: _____ Luogo: _____ Firma: _____

Disclaimer legale

Questo documento è un modello da personalizzare per la propria realtà aziendale e **non costituisce parere legale**. Per applicazioni con obblighi specifici (settori regolati, decisioni AI ad alto rischio, trattamenti particolari di dati), consultare il proprio consulente legale o un esperto di protezione dei dati.

© 2026 Aliosha Battaglini · aiosha.it · info@aiosha.it